OWASP TOP 10:2025 ASSESSMENT COVERAGE MATRIX

Epotech Cybersecurity Platform — Static & Dynamic Testing Scope Ledger

131	81	55	26	9	50
PLANNED TESTS	EXECUTED	PASSED	FAILED	CONFIRMED FLAWS	NOT TESTED

MASTER OWASP TOP 10:2025 COVERAGE TABLE

ID	VULNERABILITY CATEGORY	APP	PLAN	EXEC	PASS	FAIL	CONF	POTENT	UN-T	STATUS
A01:2025	Broken Access Control	Yes	12	9	6	3	2	1	3	FAIL
A02:2025	Security Misconfiguration	Yes	14	11	7	4	2	1	3	FAIL
A03:2025	Software Supply Chain Failures	Yes	12	8	8	0	0	1	4	PASS
A04:2025	Cryptographic Failures	Yes	12	8	5	3	2	0	4	FAIL
A05:2025	Injection	Yes	13	8	7	1	0	1	5	PASS (PARTIAL)
A06:2025	Insecure Design	Yes	13	10	7	3	1	1	3	FAIL
A07:2025	Authentication Failures	Yes	15	10	6	4	2	1	5	FAIL
A08:2025	Software or Data Integrity Failures	Yes	12	7	6	1	0	1	5	PASS (PARTIAL)
A09:2025	Security Logging and Alerting Failures	Yes	12	4	3	1	1	1	8	FAIL
A10:2025	Mishandling of Exceptional Conditions	Yes	14	6	4	2	1	1	8	FAIL

**Abbreviations: App = Applicable, Plan = Planned, Exec = Executed, Pass = Passed, Fail = Failed, Conf = Confirmed Findings, Potent = Potential Findings, Un-T = Untested Items.*

DETAILED EVALUATOR NOTES & OBSERVATIONS (A01 - A05)

A01:2025 — Broken Access Control

FAIL

Planned: 12 | Executed: 9 | Passed: 6 | Failed: 3 | Confirmed: 2 | Potential: 1 | Untested: 3

Evaluator Notes: Critical: email-based admin escalation (`auth.js`); HIGH: overly permissive Row-Level Security (RLS) policies allowing unauthenticated read/write access on Supabase tables. Dynamic IDOR tests were not executed due to the absence of a live application deployment URL.

A02:2025 — Security Misconfiguration

FAIL

Planned: 14 | Executed: 11 | Passed: 7 | Failed: 4 | Confirmed: 2 | Potential: 1 | Untested: 3

Evaluator Notes: Critical HTTP headers missing in `vercel.json`, including `Strict-Transport-Security` (HSTS) and `X-Frame-Options`. The Content Security Policy (CSP) is significantly weakened by `'unsafe-inline'`. Production TLS configurations were not runtime-verified.

A03:2025 — Software Supply Chain Failures

PASS

Planned: 12 | Executed: 8 | Passed: 8 | Failed: 0 | Confirmed: 0 | Potential: 1 | Untested: 4

Evaluator Notes: Clean dependency analysis via `npm audit` showing 0 known CVEs across 319 packages. GitHub Actions CI/CD pipeline references pinned commit hashes. Python `requirements.txt` dependencies for backend serverless functions were not available for scan.

A04:2025 — Cryptographic Failures

FAIL

Planned: 12 | Executed: 8 | Passed: 5 | Failed: 3 | Confirmed: 2 | Potential: 0 | Untested: 4

Evaluator Notes: Production database secrets, Supabase Anon JWTs, and Vercel OIDC tokens were committed directly into version-controlled environment files (`.env`, `.env.local`). Data-at-rest encryption settings could not be inspected directly on managed Supabase infrastructure.

A05:2025 — Injection

PASS (PARTIAL)

Planned: 13 | Executed: 8 | Passed: 7 | Failed: 1 | Confirmed: 0 | Potential: 1 | Untested: 5

Evaluator Notes: No SQL injection vectors were identified in client-side ORM calls, as all queries utilize the parameterized Supabase JS SDK. The referenced FastAPI backend (`/api/index.py`) was absent from the repository and unreviewed. Dynamic XSS payloads were not executed in runtime.

DETAILED EVALUATOR NOTES & OBSERVATIONS (A06 - A10)

A06:2025 — Insecure Design

FAIL

Planned: 13 | Executed: 10 | Passed: 7 | Failed: 3 | Confirmed: 1 | Potential: 1 | Untested: 3

Evaluator Notes: Design incorporates intentional authentication bypasses via offline demo session fallbacks. The `authConfirmed` scan checkbox provides a false sense of security and is non-binding. No rate-limiting mechanisms or anti-automation defenses were observed.

A07:2025 — Authentication Failures

FAIL

Planned: 15 | Executed: 10 | Passed: 6 | Failed: 4 | Confirmed: 2 | Potential: 1 | Untested: 5

Evaluator Notes: Password policy permits weak 6-character passwords. Quick-login "Admin Persona" buttons bypass authentication entirely. Offline fallback automatically issues valid local storage sessions without server validation. Multi-Factor Authentication (MFA) is absent.

A08:2025 — Software or Data Integrity Failures

PASS (PARTIAL)

Planned: 12 | Executed: 7 | Passed: 6 | Failed: 1 | Confirmed: 0 | Potential: 1 | Untested: 5

Evaluator Notes: No insecure object deserialization flaws were found. However, client-side code blindly trusts unverified `localStorage` session objects to make routing decisions. CI/CD pipelines use repository secrets correctly without leaking build artifacts.

A09:2025 — Security Logging and Alerting Failures

FAIL

Planned: 12 | Executed: 4 | Passed: 3 | Failed: 1 | Confirmed: 1 | Potential: 1 | Untested: 8

Evaluator Notes: Authentication and authorization failures are emitted only to developer browser consoles (`console.warn`). No Sentry error tracking events are configured for authorization denials, and central SIEM/log infrastructure was unverified.

A10:2025 — Mishandling of Exceptional Conditions

FAIL

Planned: 14 | Executed: 6 | Passed: 4 | Failed: 2 | Confirmed: 1 | Potential: 1 | Untested: 8

Evaluator Notes: Network errors during Supabase authentication trigger a catch block that incorrectly grants an offline admin session (EPOTK-004). Verbose error details are exposed directly to end-users via UI alerts. Backend exception handling was unreviewable.

ASSESSMENT METHODOLOGY & LIMITATIONS DISCLAIMER: This matrix reflects findings derived from static source code review and configuration analysis performed on 2026-10-29. Dynamic runtime testing against live infrastructure was not executed due to the absence of an accessible staging URL. Retesting is required following remediation.